Energía Nacional S.A. de C.V. (ENSA)

Línea base de seguridad de la información

Diagnóstico de impacto y de riesgos, seis controles prioritarios y ruta de 36 meses hacia las 153 salvaguardas de CIS Controls v8.1, Grupo de Implementación 3

Presentado a la Gerencia General de ENSA

Nexo Crítico Consultores · Alejandra Beltrán Rivas, Diego Salguero Martínez, Mariela Cortez Aguilar, Rodrigo Peña Escobar, Iván Cardoza Linares, Paola Mena Quintanilla

San Salvador, noviembre de 2026

2 procesos críticos	**14** riesgos evaluados	**6** controles diseñados	**153** salvaguardas IG3

ENSA, el encargo y el alcance del trabajo

Distribuidora de energía eléctrica para clientes residenciales e industriales: 550 empleados, un centro de operaciones en San Salvador y doce subestaciones principales conectadas al sistema de control.

Qué se construyó, en cuatro etapas

1 · Impacto en el negocio

Cuánto cuesta y cuánto tolera ENSA la interrupción de cada proceso

2 · Riesgos

Qué amenazas pueden causar esa interrupción y con qué probabilidad

3 · Controles

Seis controles diseñados a fondo para los riesgos mayores

4 · Línea base y ruta

Las 153 salvaguardas del IG3 con su estado y un plan de 36 meses

Alcance del sistema de gestión

- Diez procesos de negocio, de la operación de la red a la nómina.
- Centro de operaciones de San Salvador: centro de control de red y centro de datos corporativo.
- Doce subestaciones principales y el centro de atención al cliente.

Exclusiones justificadas

- Red inalámbrica de invitados: no sostiene ningún proceso y está aislada.
- Videovigilancia de subestaciones: programa propio de la Gerencia Técnica; entra en la próxima revisión del alcance.

Fuente: E.02, compromiso de la dirección y alcance; perfil de ENSA en el catálogo; ficha de datos del cliente (doce subestaciones).

Qué le cuesta a ENSA detenerse

De diez procesos analizados, dos son críticos; el comercial y el de medición resultan importantes. El telecontrol de la red tolera cuatro horas; la facturación, setenta y dos. Esa diferencia decide dónde se invierte primero.

Proceso y clase en el BIA	Tolera como máximo (MTPD)	Debe volver en (RTO)	Datos que puede perder (RPO)	Costo por hora (USD)
Red de control (SCADA) · crítico	4 h	2 h	15 min	62 000
Gestión de interrupciones · crítico	8 h	4 h	1 h	18 500
Comercial y facturación · importante	72 h	24 h	4 h	7 400
Medición inteligente (AMI) · importante	48 h	24 h	6 h	2 900

USD 62 000

por hora sin telecontrol en temporada de lluvias

1,49 M

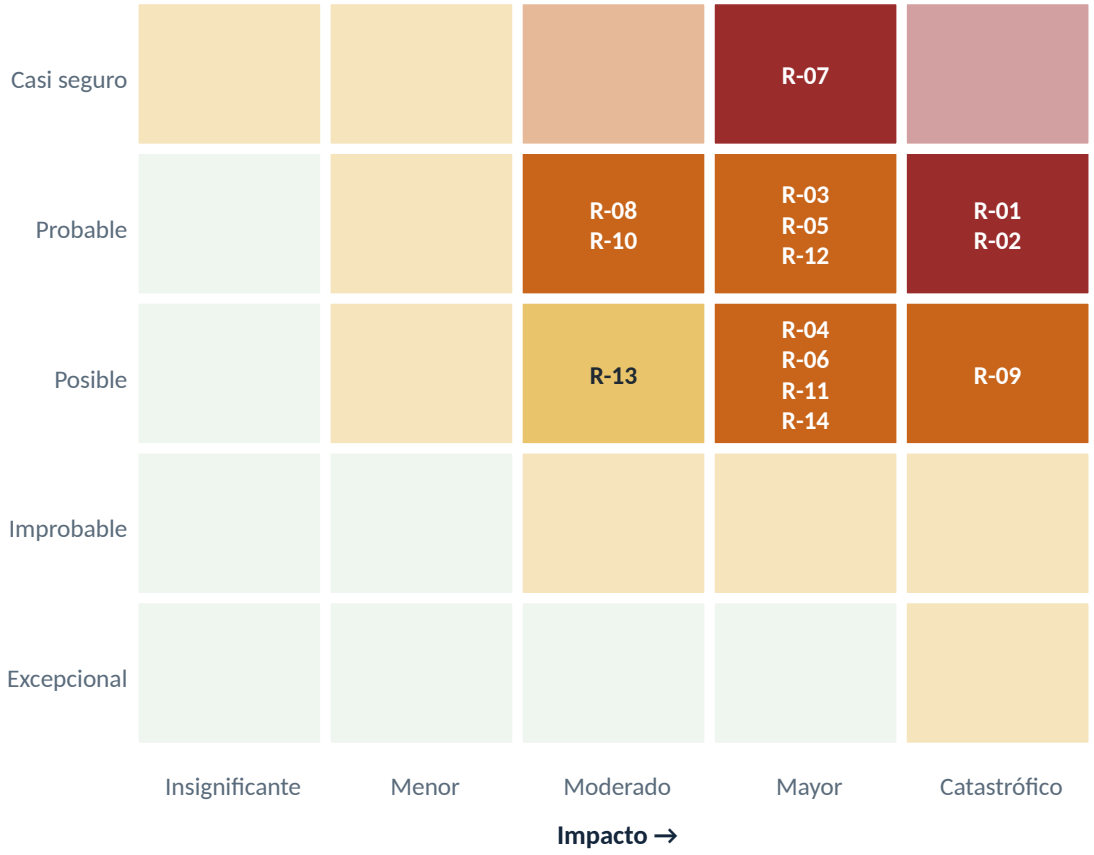
dólares por día sin telecontrol

Tres dependencias sin alternativa (puntos únicos de falla). El respaldo del sistema de control es semanal, en cinta y sin copia aislada: con él no se cumplen las dos horas de recuperación. El proveedor del sistema entra por un acceso remoto permanente con usuario compartido. Un solo ingeniero conoce la configuración del sistema de control.

Fuente: E.03, secciones B.1, B.2 y B.4 (BIA_P02 a BIA_P06). MTPD: período tras el cual el daño es irreversible. Cifras de la ficha de datos del cliente y derivadas de ella.

Catorce riesgos evaluados: tres Críticos con una sola raíz

La red corporativa (TI) y la red que controla la distribución eléctrica (OT) están conectadas en la práctica y esa conexión no está gobernada.



Los tres riesgos Críticos

R-01 Ransomware que cruza de la red corporativa al sistema de control.

R-02 Uso indebido del acceso remoto del proveedor del sistema de control, sin segundo factor ni registro.

R-07 Credenciales de administración robadas por phishing dirigido.

Diez riesgos Altos y uno Medio

Entre los Altos: intrusión no detectada en la red OT (R-03), respaldo que no restaura (R-06) y vulnerabilidades sin parchear (R-12).

Apetito aprobado: ningún riesgo Crítico o Alto queda sin tratar. Con los controles operando, los catorce bajan a Medio o Bajo.

Fuente: E.05, registro D.5, mapa D.5-bis y apetito D.4-bis. Nivel = probabilidad × impacto: Crítico ≥ 20, Alto 12–19, Medio 5–11, Bajo ≤ 4.

Seis controles elegidos desde los riesgos

Cada control trata riesgos concretos y lleva una regla verificable: una auditoría puede comprobar si se cumple o no.

Control CIS v8.1	Riesgos que trata	Regla que lo hace verificable	Función NIST CSF 2.0
12 · Infraestructura de red	R-01, R-03, R-11	Toda sesión de TI hacia la red OT pasa por el anfitrión de salto.	Proteger
13 · Monitoreo de la red	R-01, R-03, R-10	Las alertas altas se atienden en 60 minutos o menos.	Detectar
6 · Control de acceso	R-02, R-07, R-09	Toda cuenta es nominal, incluidas las del fabricante, y la administración exige segundo factor.	Proteger
7 · Vulnerabilidades	R-12 (y R-01, R-04)	Las vulnerabilidades críticas se corrigen en 15 días; las de OT, en ventana acordada.	Identificar
11 · Recuperación de datos	R-06 (y R-01)	Ninguna restauración se da por buena sin verificación firmada por el dueño del proceso.	Recuperar
15 · Proveedores	R-09, R-02, R-14	Todo proveedor crítico firma un anexo de seguridad y entrega evidencia anual.	Gobernar

El argumento económico

Segmentar y vigilar la red de control (riesgo R-01)

USD 2,48 M → 0,99 M

pérdida anual esperada, antes y después

USD 186 000

costo anual del control

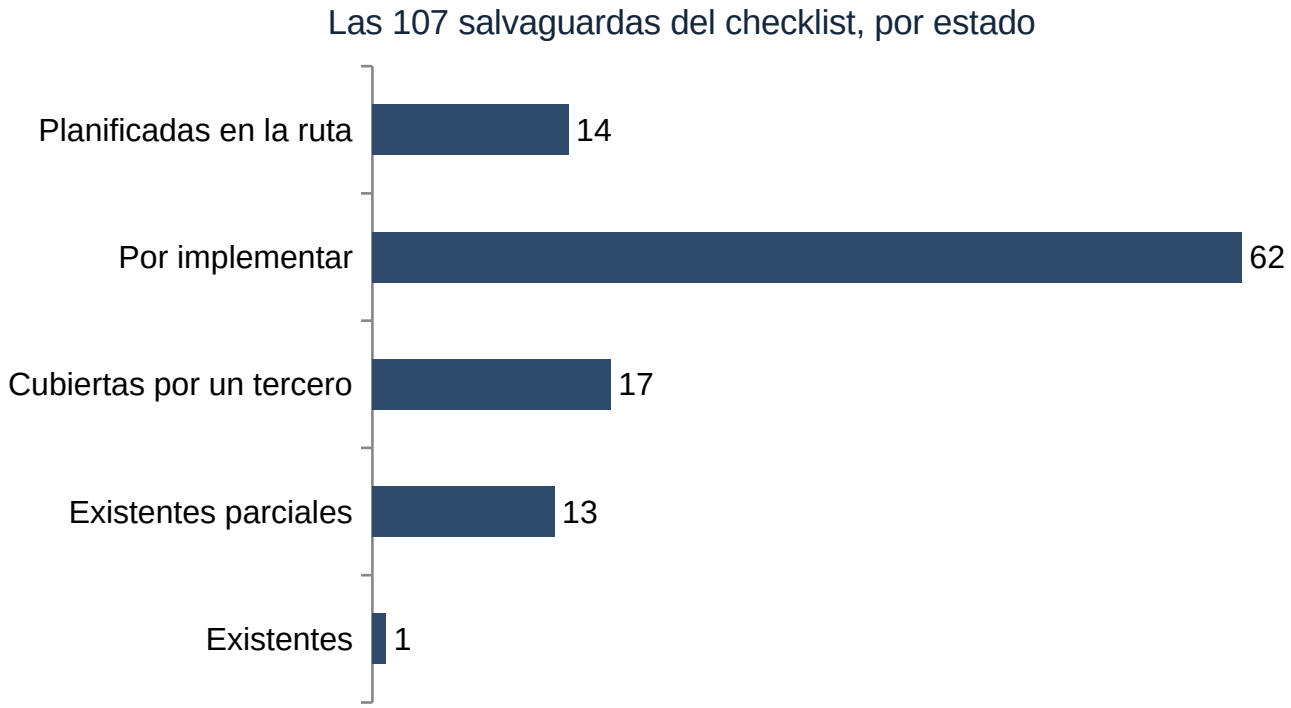
698 %

retorno esperado; 219 % en el escenario más conservador

Fuente: E.07 (políticas y procedimientos por control), E.11 §8, E.09 (metas) y E.05, tablas D.6 y D.7. Retorno = (beneficio − costo anual) ÷ costo anual.

La línea base: 153 salvaguardas y su estado hoy

Cada salvaguarda de CIS Controls v8.1 para el IG3 quedó mapeada con la medida que la cubre en ENSA, su estado actual y la evidencia exigible.



153

salvaguardas del IG3 = 107 en el checklist + 46 dentro de los seis controles

56

de higiene esencial (IG1): 41 en el checklist + 15 en los controles

Criterio: se marcó «existente» solo lo que la ficha registra como control que ya existe.

Lectura para la dirección: el punto de partida es de madurez baja. Declararlo con exactitud es lo que permite planificar y medir el avance.

Fuente: E.08, checklist del baseline IG3, y E.07, F.1 de los seis controles; conteo verificado contra CIS Controls v8.1 (56 IG1 + 74 IG2 + 23 IG3).

Cómo sabrá ENSA que funciona

Doce indicadores, dos por control, alimentados por la evidencia que genera cada procedimiento; una auditoría interna verifica que lo medido es cierto.

Tres indicadores con meta de 100 %, sin tolerancia

100 % — **IND-05 · Cuentas privilegiadas con segundo factor**
Mensual · trata R-07

100 % — **IND-06 · Sesiones de proveedor dentro de ventana autorizada y grabadas**
Mensual · trata R-02

100 % — **IND-10 · Pruebas de restauración del sistema de control dentro del objetivo de 2 h**
Trimestral · trata R-06 y R-01

Por qué sin tolerancia: cada uno corresponde a un riesgo Crítico, y una sola excepción reabre la condición que lo hizo Crítico.

Auditoría interna

- Del 9 al 20 de marzo de 2027; informe final el 31 de marzo.
- Auditor independiente de Seguridad y de TI/TO, con apoyo externo.
- Verifica la evidencia de los doce indicadores y de las reglas de los seis controles.
- Los otros nueve indicadores tienen metas de 90 % a 99 % con umbral de alerta.

Fuente: E.09, tablas H.1 (indicadores) y H.2 (programa de auditoría interna simulada).

La ruta de 36 meses hacia el IG3

Veintinueve iniciativas en tres horizontes, ordenadas por dependencia: el respaldo va primero porque sin él cualquier incidente supera el tiempo que ENSA tolera.

Corto plazo · 0–6 meses

USD 392 000

13 iniciativas · 60 salvaguardas

Qué incluye

- Respaldo aislado del sistema de control
- Segmentación TI–OT y FortiOS 7.4
- Segundo factor, cuentas y acceso de proveedores
- Inventario TI y OT, datos y software
- Vulnerabilidades, configuración y Windows 11
- Concientización y anexos de proveedores

Mediano plazo · 6–18 meses

USD 265 000

11 iniciativas · 57 salvaguardas

Qué incluye

- Bitácoras centralizadas
- Monitoreo pasivo de la red OT
- Respuesta a incidentes con ejercicios
- Protección de datos, correo y malware
- Accesos por rol y dispositivos de campo
- Software, proveedores y aplicaciones

Largo plazo · 18–36 meses

USD 180 000

5 iniciativas · 18 salvaguardas

Qué incluye

- Prevención de fuga de datos
- Defensa activa de red
- Seguridad de aplicaciones
- Administración dedicada
- Control de software

Total: USD 837 000 cotizados en 36 meses, más FortiOS 7.4 y Windows 11 por cotizar. El primer año cabe en los USD 480 000 aprobados.

Fuente: E.10, roadmap I.1, tabla I.2 (18 salvaguardas operan hoy, 78 al cierre del corto plazo) y tabla de horizontes; presupuesto: ficha de datos del cliente (E.02), con la sensibilidad S-14. Al cierre del corto plazo ningún riesgo Crítico o Alto conserva su nivel inherente.

Lo que se solicita a la dirección

Aprobar las seis medidas prioritarias, en este orden

1. Respaldo del sistema de control con copia aislada y prueba de restauración trimestral
2. Segmentación de los puntos de conexión entre la red corporativa y la red OT
3. Acceso remoto de proveedores con cuentas nominales, segundo factor y grabación
4. Segundo factor en toda cuenta administrativa y capacitación frente a la suplantación con IA
5. Inventario y detección en la red OT
6. Documentación del sistema de control y un segundo ingeniero formado

Decisión 1 · Validar la operación manual

El simulacro de marzo sostuvo 8 horas; la ficha declara 12. Si rige el simulacro, la tolerancia del telecontrol baja y el objetivo de recuperación se endurece.

Decisión 2 · Renegociar el contrato del fabricante

El anexo de seguridad del contrato del sistema de control condiciona tres de las seis medidas.

Ninguna medida exige tecnología excepcional; todas exigen decisión, presupuesto y disciplina de operación.

Anexo A · Datos y supuestos que sostienen las cifras

Las cifras económicas salen de la ficha de datos del cliente o se derivan de ella; lo que la ficha no trae se declaró como supuesto con origen y rango, y la conclusión se probó en tres escenarios.

Dato o supuesto (origen)	Mínimo	Esperado	Máximo	¿Gobierna la conclusión?
Ingresos no percibidos por hora sin telecontrol (derivado de la ficha)	USD 24 000	USD 38 000	USD 55 000	No
Compensaciones contractuales por hora (ficha)	USD 2 000	USD 4 500	USD 9 000	No
Valor del proceso de control de red (derivado de la ficha)	USD 6,5 M	USD 9,0 M	USD 12,0 M	Sí
S-12 · Fracción del valor perdida en el evento de referencia	0,40	0,55	0,70	Sí
Horas sostenibles de operación manual (ficha)	8 h	12 h	16 h	Sí
S-14 · Presupuesto anual de seguridad de 2028 y 2029	USD 300 000	USD 480 000	USD 600 000	Sí, sobre la ruta

Resultado de la prueba: la recomendación de tratar el riesgo sobre el sistema de control se sostiene en los tres escenarios; el retorno pasa de 698 % en el esperado a 219 % en el más conservador. Diecisiete identificadores de supuesto, siete sin uso porque el dato sale de la ficha.

Fuente: ficha de datos del cliente de ENSA; E.03, sección B.5; BIA_P06, registro de supuestos; E.05, tabla D.7.

Anexo B · Las veintinueve iniciativas de la ruta

Cada iniciativa agrupa salvaguardas que se implantan juntas y tiene un responsable en la organización.

Corto (0–6 meses)

1. Respaldo aislado del sistema de control
2. Segmentación TI–OT
3. Segundo factor y acceso remoto
4. Concentrador de acceso para proveedores
5. Inventario de activos TI y OT
6. Gestión de vulnerabilidades con ventanas
7. Configuración segura y retiro de credenciales de fábrica
8. Concientización y capacitación
9. Inventario y anexos de proveedores
10. Migración a FortiOS 7.4
11. Windows 11 y software con soporte
12. Gestión de cuentas
13. Gestión de datos

Mediano (6–18 meses)

1. Bitácoras centralizadas y sincronización
2. Monitoreo pasivo de la red OT
3. Respuesta a incidentes con ejercicios
4. Clasificación, cifrado y retención de datos
5. Protección de correo y navegación
6. Defensas contra malware
7. Cuentas y acceso centralizados por rol
8. Dispositivos portátiles de campo
9. Inventario de software autorizado
10. Evaluación de proveedores
11. Configuración de aplicaciones

Largo (18–36 meses)

1. Prevención de fuga de datos
2. Defensa activa de red
3. Seguridad de aplicaciones
4. Administración con recursos dedicados
5. Control de scripts y bibliotecas

Fuente: E.10, plantilla I.1 del roadmap, con salvaguardas, IG, responsable, dependencias y resultado esperado de cada iniciativa.